



Strategic Implementation Roadmap (3 - 6 - 12 Mesi)

Piano di Remediation e Percorso verso la Certificazione ISO/IEC 27001:2022

Standard di Riferimento: ISO/IEC 27001:2022 & NIST CSF v1.1

Organizzazione: Aetheris Therapeutics S.p.A.

Rif. Documento: EXEC-RDM-2026-03

Versione: 1.0

Stato: Approvato

Classificazione: Riservato / Riservato al Board

Data di Efficacia: Agosto 2026

1. Visone Strategica e Timeline Complessiva

La presente **Strategic Roadmap** scandisce la traiettoria operativa e metodologica che **Aetheris Therapeutics S.p.A.** seguirà nei prossimi 12 mesi.

L'obiettivo principale è colmare le Non-Conformità emerse nell'audit di **Agosto 2026**, elevare la maturità cyber aziendale dal livello attuale (Tier 1) a quello target (Tier 3) e guidare l'organizzazione all'ottenimento della certificazione **ISO/IEC 27001:2022** entro **Agosto 2027**.

2. Matrice Sintetica delle Fasi Temporal

Fase	Orizzonte Temporale	Focus Strategico	Obiettivo Principale
Fase 1	Mesi 1 - 3 (Q3/Q4 2026)	Emergency Mitigation & GDPR Base	Abbattimento delle 5 Non-Conformità Maggiori e messa in sicurezza degli accessi remoti.
Fase 2	Mesi 4 - 6 (Q1 2027)	Technical Controls & SOC Deploy	Implementazione PAM, attivazione SIEM/SOC h24 e strumento automatizzato ITAM.
Fase 3	Mesi 7 - 9 (Q2 2027)	SGSI Governance & Policy Rollout	Aggiornamento documentale, formazione awareness e gestione sicurezza fornitori.
Fase 4	Mesi 10 - 12 (Q3 2027)	Internal Audit & Certification	Re-audit interno ISO 19011, Management Review e Audit di Certificazione Stage 1 & 2.

3. Dettaglio Operativo delle Fasi di Implementazione

FASE 1: Mesi 1 – 3 (Settembre – Novembre 2026) — Remediation Critica

Mese 1: Enforce della Sicurezza sugli Accessi Remoti & Privileged Access

- **Azione 1.1 (MFA su VPN):** Integrazione gateway Palo Alto con Azure AD via SAML 2.0 e applicazione regole di Conditional Access con MFA obbligatorio per tutti gli utenti remoti. (Ref: NC-MAJ-01 / RTP-01)
- **Azione 1.2 (Privileged Accounts Management):** Disattivazione credenziali Domain Admin condivise; assegnazione di account nominali distinti per le attività sistemistiche. (Ref: NC-MAJ-02 / RTP-02)

Mese 2: Compliance Privacy & Incident Response Framework

- **Azione 1.3 (Registro Trattamenti GDPR):** Mappatura dei flussi dati clinici e PII nei laboratori R&D e redazione formale del Registro Art. 30 GDPR. (Ref: NC-MAJ-04 / RTP-03)

- **Azione 1.4 (Incident Response Plan):** Stesura dell'Incident Response Plan (IRP) conforme a NIST SP 800-61, formalizzazione della matrice di escalation e costituzione del CIRT. (Ref: NC-MAJ-03 / RTP-05)

Mese 3: Testing & Risk Treatment Review

- **Azione 1.5 (Tabletop Simulation):** Esecuzione di una simulazione d'incidente (Tabletop exercise) con la partecipazione del Board e del CIRT per validare l'IRP.
- **Azione 1.6 (Milestone Check 1):** Verifica dell'azzeramento dei rischi critici RISK-01 e RISK-02 .

● FASE 2: Mesi 4 – 6 (Dicembre 2026 – Febbraio 2027) — Technical Controls & Monitoring

Mese 4: Implementazione PAM Vault & ITAM Automation

- **Azione 2.1 (PAM Vault Rollout):** Deploy della soluzione Privileged Access Management per la rotazione automatica e la gestione protetta delle password di root e amministrazione. (Ref: NC-MAJ-02 / RTP-02)
- **Azione 2.2 (IT Asset Discovery):** Installazione dello strumento di IT Asset Management con discovery automatica dei dispositivi connessi alla rete. (Ref: NC-MIN-01 / RTP-06)

Mese 5: Deploy SIEM Sentinel & Attivazione SOC h24

- **Azione 2.3 (SIEM Integration):** Configurazione di Microsoft Sentinel ed inoltro dei log prodotte da Firewall Palo Alto, Active Directory, Azure AD e server R&D. (Ref: NC-MAJ-05 / RTP-04)
- **Azione 2.4 (MSSP SOC Onboarding):** Attivazione del servizio SOC gestito in outsourcing h24 per la correlazione degli eventi e l'Incident Escalation. (Ref: RTP-04)

Mese 6: Data Loss Prevention & Endpoint Protection

- **Azione 2.5 (Purview DLP Enforce):** Configurazione delle policy DLP su Microsoft 365 / Purview per bloccare l'uscita non autorizzata di brevetti e PII. (Ref: RTP-03 / OFI-03)
- **Azione 2.6 (Milestone Check 2):** Collaudo del flusso di segnalazione SOC ed azzeramento del rischio RISK-04 .

● FASE 3: Mesi 7 – 9 (Marzo – Maggio 2027) — Governance & Security Culture

Mese 7: Security Policy Rollout & Supplier Governance

- **Azione 3.1 (Politica di Sicurezza SGSI):** Revisione, formalizzazione e approvazione da parte del Board della Policy IT e delle procedure operative. (Ref: NC-MIN-02)
- **Azione 3.2 (Supplier Risk Management):** Introduzione del Security Annex e clausole di audit nei contratti con fornitori SaaS/IT terzi. (Ref: NC-MIN-04 / RTP-07)

Mese 8: Security Awareness & HR Screening

- **Azione 3.3 (Phishing Campaign & Training):** Avvio delle campagne periodiche di Phishing Simulation per tutto il personale dipendente. (Ref: OFI-02)
- **Azione 3.4 (HR Onboarding Check-list):** Formalizzazione della procedura di screening del personale neo-assunto con accesso ad asset critici. (Ref: NC-MIN-03)

Mese 9: EDR Upgrade & Pre-Audit Internal Review

- **Azione 3.5 (EDR Rollout su Workstation):** Upgrade della protezione antivirus su workstation R&D a soluzione EDR comportamentale. (Ref: OFI-01 / RTP-08)
- **Azione 3.6 (Milestone Check 3):** Verifica del 100% di chiusura di tutte le Non-Conformità Maggiori e Minori.

FASE 4: Mesi 10 – 12 (Giugno – Agosto 2027) — Internal Audit & Certificazione ISO 27001

Mese 10: Internal Audit ISO 19011

- **Azione 4.1 (Internal Audit SGSI):** Esecuzione dell'Audit Interno formale su tutte le clausole ISO 27001:2022 (4–10) e controlli Annex A secondo la norma ISO 19011.
- **Azione 4.2 (Corrective Action Closeout):** Chiusura delle eventuali osservazioni emerse durante l'audit interno.

Mese 11: Management Review (Riesame della Direzione)

- **Azione 4.3 (Riesame della Direzione):** Convocazione formale del Board per l'approvazione del Riesame della Direzione (Clausola 9.3) e valutazione dell'efficacia del SGSI.

Mese 12: Audit di Certificazione Ufficiale (Stage 1 & Stage 2)

- **Azione 4.4 (Stage 1 Audit):** Verifica documentale da parte dell'Ente di Certificazione accreditato (Verifica conformità SGSI e SoA).
- **Azione 4.5 (Stage 2 Audit):** Verifica sul campo dell'effettiva applicazione dei controlli e raccomandazione per il Rilascio della Certificazione ISO/IEC 27001:2022.

4. Controllo Documentale e Approvazione (ISO 27001:2022 Clausola 7.5)

Ruolo	Nome e Cognome	Stato	Data
Redatto da (Lead Auditor)	Emanuele Tarchi	Completato	Agosto 2026
Revisionato da (IT Director)	IT Director ad interim	Revisionato	Agosto 2026
Approvato da (Alta Direzione)	Chief Executive Officer (CEO)	Approvato	Agosto 2026